Serve una valutazione d'impatto sulla protezione dei dati (DPIA)?

Una checklist per capire se un trattamento richiede una valutazione d'impatto sulla protezione dei dati. Per ogni riga spunta sì, no o non so. Scrivi a chi hai chiesto.

PER CHI
Edizione italiana. Per il titolare del trattamento in Italia che deve decidere se un trattamento richiede una valutazione d'impatto sulla protezione dei dati (DPIA), e per il professionista che lo assiste. Le regole per la Germania sono nell'edizione in inglese: https://finoprivacy.com/documents/dpia-screening.html

NON COPERTO
La valutazione d'impatto in sé. Gli elenchi nazionali degli altri Paesi (art. 35, par. 4). Nessuna corrispondenza con un elenco non significa che la valutazione non serva.

STATO DELLA NORMATIVA
GDPR (Regolamento (UE) 2016/679), testo italiano consolidato su EUR-Lex, letto l'8 novembre 2026; WP 248 rev.01 del 4 ottobre 2017, versione italiana (le pagine citate sono quelle del PDF italiano); provvedimento del Garante n. 467 dell'11 ottobre 2018 e relativo Allegato 1; chiarimento interpretativo sulla pagina DPIA del Garante, letto l'8 novembre 2026

VERSIONE
1.0, 8 novembre 2026

TRATTAMENTO _____ TITOLARE DEL TRATTAMENTO _____

COMPILATO DA _____ DATA _____

Passo 1. I tre casi in cui l'art. 35, par. 3, richiede sempre una valutazione d'impatto

Spunta sì per ogni caso che ricorre. Ne basta uno.

VOCE	CHE COSA DICE	SÌ	NO	?
Art. 35, par. 3, lett. a) GDPR	Valuti in modo sistematico e globale aspetti personali delle persone con un trattamento automatizzato, compresa la profilazione, e su questa base prendi decisioni che hanno effetti giuridici o incidono in modo analogo significativamente su di loro.	☐	☐	☐
Art. 35, par. 3, lett. b) GDPR	Tratti su larga scala categorie particolari di dati personali o dati relativi a condanne penali e a reati.	☐	☐	☐
Art. 35, par. 3, lett. c) GDPR	Sorvegli in modo sistematico e su larga scala una zona accessibile al pubblico (per esempio con telecamere su una strada).	☐	☐	☐

Passo 2. I nove criteri del WP 248 rev.01 (Gruppo di lavoro Articolo 29, linee guida fatte proprie dall'EDPB)

WP 248 (pag. 12 della versione italiana): "Nella maggior parte dei casi, un titolare del trattamento può considerare che un trattamento che soddisfi due criteri debba formare oggetto di una valutazione d'impatto sulla protezione dei dati." Conta i sì. Per

il Garante "il ricorrere di due o più dei predetti criteri è indice di un trattamento che presenta un rischio elevato", per il quale la valutazione è richiesta (provvedimento n. 467/2018).

VOCE	CHE COSA DICE	SÌ	NO	?
Criterio 1 WP 248 rev.01	Valutazione o assegnazione di un punteggio, compresa la profilazione e la previsione (per esempio su rendimento professionale, situazione economica, salute, interessi, affidabilità, comportamento, ubicazione o spostamenti).	☐	☐	☐
Criterio 2 WP 248 rev.01	Processo decisionale automatizzato che ha effetto giuridico o incide in modo analogo significativamente sulle persone.	☐	☐	☐
Criterio 3 WP 248 rev.01	Monitoraggio sistematico delle persone.	☐	☐	☐
Criterio 4 WP 248 rev.01	Dati sensibili o dati aventi carattere altamente personale.	☐	☐	☐
Criterio 5 WP 248 rev.01	Trattamento di dati su larga scala.	☐	☐	☐
Criterio 6 WP 248 rev.01	Creazione di corrispondenze o combinazione di insiemi di dati.	☐	☐	☐
Criterio 7 WP 248 rev.01	Dati relativi a interessati vulnerabili.	☐	☐	☐
Criterio 8 WP 248 rev.01	Uso innovativo o applicazione di nuove soluzioni tecnologiche od organizzative.	☐	☐	☐
Criterio 9 WP 248 rev.01	Il trattamento in sé impedisce alle persone di esercitare un diritto o di avvalersi di un servizio o di un contratto.	☐	☐	☐

Passo 3. L'elenco del Garante (provvedimento n. 467 dell'11 ottobre 2018, Allegato 1)

Il Garante precisa che l'elenco "è riferito esclusivamente a tipologie di trattamento soggette al meccanismo di coerenza e che non è esaustivo" (provvedimento n. 467/2018). La voce 5 riguarda il controllo dei dipendenti con videosorveglianza e geolocalizzazione. Secondo il chiarimento interpretativo del Garante, i trattamenti "sistematici" e "non occasionali" delle voci 6, 11 e 12 corrispondono al criterio della larga scala (criterio 5 del WP 248) (Garante, pagina DPIA).

VOCE	CHE COSA DICE	SÌ	NO	?
Voce 1 Garante 467/2018	Trattamenti valutativi o di scoring su larga scala, oppure trattamenti che profilano le persone o fanno previsioni su di loro, anche online o con app, su aspetti come rendimento professionale, situazione economica, salute, preferenze, affidabilità, comportamento, ubicazione o spostamenti	☐	☐	☐
Voce 2 Garante 467/2018	Trattamenti automatizzati per prendere decisioni che producono effetti giuridici o incidono in modo analogo significativamente sulla persona, comprese le decisioni che le impediscono di esercitare un diritto, di avvalersi di un bene o di un servizio o di restare parte di un contratto	☐	☐	☐
Voce 3 Garante 467/2018	Uso sistematico di dati per osservare, monitorare o controllare le persone, compresi i dati raccolti tramite reti, online o con app, gli identificativi univoci degli utenti di servizi della società dell'informazione rispetto alle abitudini d'uso e ai dati di visione per periodi prolungati, e i metadati trattati per ragioni organizzative, di budget, di aggiornamento tecnologico, delle reti, antifrode, antispam o di sicurezza	☐	☐	☐

VOCE	CHE COSA DICE	SÌ	NO	?
Voce 4 Garante 467/2018	Trattamenti su larga scala di dati aventi carattere estremamente personale (WP 248, rev. 01): per esempio dati legati alla vita familiare o privata, dati che incidono sull'esercizio di un diritto fondamentale, o dati la cui violazione ha un grave impatto sulla vita quotidiana	☐	☐	☐
Voce 5 Garante 467/2018	Trattamenti nel rapporto di lavoro con sistemi tecnologici (anche videosorveglianza e geolocalizzazione) dai quali derivi la possibilità di controllare a distanza l'attività dei dipendenti	☐	☐	☐
Voce 6 Garante 467/2018	Trattamenti non occasionali (per il chiarimento interpretativo del Garante, su larga scala) di dati di soggetti vulnerabili (minori, disabili, anziani, infermi di mente, pazienti, richiedenti asilo)	☐	☐	☐
Voce 7 Garante 467/2018	Trattamenti con tecnologie innovative (per esempio Internet delle cose (IoT), intelligenza artificiale, assistenti vocali online, dispositivi wearable, tracciamenti di prossimità come il wi-fi tracking), quando ricorre anche almeno un altro criterio del WP 248	☐	☐	☐
Voce 8 Garante 467/2018	Trattamenti che comportano lo scambio di dati su larga scala tra diversi titolari con modalità telematiche	☐	☐	☐
Voce 9 Garante 467/2018	Trattamenti mediante interconnessione, combinazione o raffronto di informazioni, compreso l'incrocio dei dati di consumo di beni digitali con dati di pagamento (per esempio mobile payment)	☐	☐	☐
Voce 10 Garante 467/2018	Trattamenti di categorie particolari di dati (art. 9) o di dati relativi a condanne penali e a reati (art. 10) interconnessi con altri dati personali raccolti per finalità diverse	☐	☐	☐
Voce 11 Garante 467/2018	Trattamenti sistematici (per il chiarimento interpretativo del Garante, su larga scala) di dati biometrici: il Garante precisa che il termine va inteso come *"dati biometrici, trattati per identificare univocamente una persona fisica"* (Garante, pagina DPIA). Si tiene conto del volume dei dati e della durata o persistenza del trattamento	☐	☐	☐
Voce 12 Garante 467/2018	Trattamenti sistematici (per il chiarimento interpretativo del Garante, su larga scala) di dati genetici, tenendo conto del volume dei dati e della durata o persistenza del trattamento	☐	☐	☐

Sanzionati, con l'art. 35 tra le violazioni

Deliveroo Italy: € 2.500.000 (Garante, 2021). Valutazione d'impatto tra le violazioni, insieme alle norme sul lavoro e sul controllo a distanza. 2021/IT/038 su Fino (pagina in inglese)

I dati sulle decisioni provengono da enforcementtracker.com (a cura di CMS) e da GDPRhub (noyb), con licenza CC BY-NC-SA 4.0 (https://creativecommons.org/licenses/by-nc-sa/4.0/), e dalle pubblicazioni delle autorità stesse; ogni pagina di decisione su Fino riporta i dettagli.

Che cosa significa il risultato

Un sì al passo 1, o una corrispondenza al passo 3: la valutazione d'impatto è richiesta (art. 35, par. 3; elenchi nazionali ai sensi dell'art. 35, par. 4). Due o più sì al passo 2: nella maggior parte dei casi la valutazione è richiesta (WP 248, pag. 12 della versione italiana). Secondo l'art. 35, par. 1 il titolare effettua la valutazione *"prima di procedere al trattamento"*.

WP 248 (pag. 9 della versione italiana): *"Nei casi in cui non è chiaro se sia richiesta una valutazione d'impatto sulla protezione dei dati o meno, il WP29 raccomanda di effettuarla comunque"*.

WP 248 (pag. 13 della versione italiana): se un trattamento soddisfa due o più criteri del passo 2 ma il titolare ritiene che non presenti un rischio elevato, *"il titolare del trattamento deve giustificare e documentare i motivi che lo hanno spinto a non effettuare una valutazione d'impatto sulla protezione dei dati, nonché includere/registrare i punti di vista del responsabile della protezione dei dati"*.

Gli elenchi non sono esaustivi. Nessuna corrispondenza non significa che la valutazione non serva. Esistono altri elenchi nazionali (art. 35, par. 4); questa checklist riporta solo quello italiano.

Fonti

GDPR, Regolamento (UE) 2016/679, art. 35, testo italiano consolidato (EUR-Lex) • Usata per: Passo 1 e la regola per cui la valutazione precede il trattamento

WP 248 rev.01, Linee guida in materia di valutazione d'impatto sulla protezione dei dati (Gruppo di lavoro Articolo 29, fatte proprie dall'EDPB), versione italiana nell'archivio delle traduzioni della pagina ufficiale (file zip) • Usata per: Passo 2, i nove criteri, e le pagine citate in "Che cosa significa il risultato"

Garante, Allegato 1 al provvedimento n. 467 dell'11 ottobre 2018 (doc. web 9059358) • Usata per: Passo 3, l'elenco italiano

Garante, provvedimento n. 467 dell'11 ottobre 2018 (doc. web 9058979) • Usata per: Portata dell'elenco; due o più criteri del WP 248

Garante, pagina sulla valutazione d'impatto (DPIA), chiarimento interpretativo • Usata per: Voci 6, 11 e 12 e la larga scala